

Junior Cloud Security Engineer

Internship Task Report

1.0 Task Overview

Task ID	CSE-AWS-L-004-04
Task Title	Cloud Threat Modeling and Attack Surface Identification in AWS
Skill Domain	AWS Cloud Security / Threat Modeling
Difficulty	Intermediate
Duration	13 Hours
CPE Credits	4 CPE Credits
Cloud Platform(s)	CloudGoat (AWS Free Tier), TryHackMe Labs
AWS Region(s) Used	us-east-2
Primary Tools	AWS CLI, CloudGoat, Threat Dragon, OWASP PyTM, ChatGPT, AWS IAM Analyzer
Target Environment	CloudGoat (AWS Free Tier), TryHackMe Labs
MITRE ATT&CK IDs	T1078 (Valid Accounts), T1087 (Account Discovery), T1530 (Data from Cloud Storage Object), T1552 (Unsecured Credentials)
Guiding Frameworks	CIS AWS Foundations Benchmark v1.5, NIST SP 800-53, ISO 27001, OWASP Cloud Top 10
Regulatory Alignment	ISO : 27001 A.9 Access Control, A.12 Operations Security; NICE PR-CDA-001; SFIA Level 3-4

1.1 Introduction

In this task, I worked with a deliberately vulnerable AWS environment to understand how cloud resources and permissions can create security risks. I used CloudGoat to deploy the lab environment, examined the AWS resources and their potential attack surfaces, and then assessed the identified threats using threat modelling and risk analysis

techniques. This is an important skill for a cloud security engineer because real-world cloud environments can become vulnerable when resources are publicly exposed, IAM permissions are too broad, or security controls are not properly configured.

1.2 Objectives & Learning Outcomes

Phase A – Theory & Introduction

Objective: Understand the principles of cloud threat modelling using the STRIDE and MITRE ATT&CK frameworks.

How I met the objective: I studied the fundamentals of cloud threat modelling and applied the STRIDE framework to identify potential threats to the CloudGoat AWS environment, while using MITRE ATT&CK to understand and map relevant attacker behaviours and techniques. I also created a Threat Dragon diagram to visually represent the cloud environment, trust boundaries, potential threats, and attack paths as required for the Phase A evidence (phaseA_threatmodel.png).

Phase B – Setup Homelab / Target Environment

Objective: Deploy the CloudGoat vulnerable environment in your AWS Free Tier account.

How I met the objective: I configured my AWS cloudgoat-lab profile, installed and configured CloudGoat and Terraform in AWS CloudShell, configured the CloudGoat IP whitelist, and deployed the iam_privesc_by_rollback vulnerable scenario using Terraform. I then verified the AWS environment and documented the deployed resources, including EC2 instances, S3 buckets, IAM users, and IAM roles, as evidence for the Phase B deployment.

Phase C – Core Execution: Attack Surface Identification

Objective: Enumerate all exposed services and identify potential attack vectors.

How I met the objective: I used AWS CLI commands to enumerate the resources deployed in the CloudGoat environment, including EC2 instances, S3 buckets, IAM users, and IAM roles. I reviewed the resource configurations and exposure to identify potential attack surfaces and security risks, mapped relevant findings to MITRE ATT&CK techniques, and documented the results in the required phaseC_attack_surface.xlsx attack surface table.

Phase D – Independent Extension: Threat Modeling & Risk Matrix

Objective: Build a complete threat model including risk ratings and mitigations.

How I met the objective: I analysed the potential threats identified during Phase C and assessed each threat based on its likelihood and potential impact. I assigned risk scores and risk ratings, mapped relevant threats to MITRE ATT&CK techniques, and recommended appropriate mitigations such as IAM least privilege, restricting public exposure, reviewing security-group rules, and protecting S3 resources. I documented the findings in the risk matrix and prepared the required phaseD_riskmatrix.png screenshot as evidence.

Phase F – Documentation & Reporting

Objective: Compile all findings into a professional report suitable for executive review.

How I met the objective: I consolidated the results from the previous phases, including the threat model, CloudGoat environment deployment, AWS attack-surface findings, identified threats, risk ratings, MITRE ATT&CK mappings, and recommended security mitigations. I organised these findings into a structured and professional report that clearly presents the security assessment results and supporting evidence for executive review, and prepared the final PDF report as AWS_ThreatModel_Report.pdf.

1.2 Scope & Legal Authorisation

All activities performed as part of this task were conducted within authorised environments for educational and cybersecurity training purposes. The assessment was limited to the AWS resources deployed for the CloudGoat lab and did not involve testing any unauthorised systems.

Authorised environments used:

- **Personal AWS Free Tier account** — Used as the authorised AWS environment for deploying and testing the CloudGoat vulnerable environment.
- **CloudGoat scenario: iam_privesc_by_rollback** — Deployed within the personal AWS account as an intentionally vulnerable training environment for cloud security assessment and threat modelling.
- **AWS CloudShell** — Used as the authorised command-line environment to configure AWS CLI, CloudGoat, and Terraform and to perform resource enumeration.
- **CloudGoat-deployed AWS resources** — Included the EC2 instances, S3 buckets, IAM users, IAM roles, and other resources created as part of the authorised lab environment.

Authorisation confirmation:

No external AWS accounts, production environments, third-party cloud resources, or real customer data were accessed or tested during this task. All security testing and enumeration activities were restricted to the authorised CloudGoat training environment deployed in my personal AWS account. ChatGPT and other AI tools were used only for analysis, explanation, documentation, and report preparation; they were not used to execute cloud commands or generate technical evidence.

1.3 MITRE ATT&CK Cloud Threat Mapping

MITRE ATT&CK Technique ID	Technique Name	Relevance to This Task
T1078	Valid Accounts	The CloudGoat environment used an authorised AWS IAM user to access and manage cloud resources. The technique is relevant because compromised or misused valid cloud credentials could provide access to AWS resources.
T1530	Data from Cloud Storage Object	The assessment identified multiple S3 buckets in the CloudGoat environment. If access controls or bucket permissions were misconfigured, an attacker could potentially access sensitive data stored in cloud storage.
T1087	Account Discovery	IAM users and roles were enumerated during the assessment to understand the identities and permissions available within the AWS environment. This information could help an attacker identify accounts and potential privilege-escalation paths.
T1580	Cloud Infrastructure Discovery	AWS resources such as EC2 instances, S3 buckets, IAM users, and IAM roles were enumerated to understand the cloud environment and identify potential attack surfaces.

MITRE ATT&CK Technique ID	Technique Name	Relevance to This Task
T1098	Account Manipulation	The iam_privesc_by_rollback CloudGoat scenario contains intentionally vulnerable IAM configurations designed to demonstrate privilege escalation. Excessive permissions or the ability to modify IAM policies could potentially allow an attacker to increase their level of access.

2.0 Environment & Tool Setup

2.1 Cloud Architecture Overview

The CloudGoat lab environment was deployed in my authorised AWS account to provide a controlled environment for practising cloud security assessment and threat modelling. The environment included AWS resources such as EC2 instances, S3 buckets, IAM users, and IAM roles. AWS CloudShell was used as the local command-line environment to configure and manage the lab, while CloudGoat and Terraform were used to deploy the vulnerable scenario.

Cloud Resource / Component	Type / Service	Role in Task	Region / Config Notes
CloudGoat IAM User (CpoudGoat-User)	AWS IAM User	Provided the authorised identity used to access and manage the CloudGoat lab environment	AWS account 938500344456; exact region not applicable to IAM
CloudGoat IAM Roles	AWS IAM Roles	Provided the identities and permissions used within the vulnerable lab environment and supported analysis of potential privilege-escalation paths	IAM is a global AWS service; included multiple CloudGoat training roles

Cloud Resource / Component	Type / Service	Role in Task	Region / Config Notes
CloudGoat EC2 Instance (i-0911635d140464495)	Amazon EC2	Running lab instance used to identify potential cloud infrastructure exposure and attack surfaces	us-east-2; t3.micro; Public IP 18.116.230.73; Private IP 172.31.42.98
Phase B EC2 Instance (i-08964f8ba50b4c8a9)	Amazon EC2	Additional CloudGoat lab resource reviewed during resource enumeration	us-east-2; t3.micro; stopped; Private IP 172.31.38.232; no public IP
CloudGoat S3 CloudTrail Logs Bucket	Amazon S3	Storage location identified during enumeration; assessed as a potential sensitive cloud storage target	aws-cloudtrail-logs-938500344456-c722b193; public access configuration not verified
CloudGoat Configuration Bucket	Amazon S3	Identified as a potential source of configuration-related data during attack-surface analysis	config-bucket-938500344456; public access configuration not verified
my-homelab-trail	Amazon S3	S3 resource reviewed for public access controls	Block Public Access settings were enabled
CloudShell	AWS CloudShell	Command-line environment used to run AWS CLI, CloudGoat, and Terraform commands	Used to configure and manage the authorised AWS lab
CloudGoat	Cloud security training framework	Used to deploy the intentionally vulnerable iam_privesc_by_rollback scenario	Deployed in the authorised personal AWS account
Terraform	Infrastructure as Code tool	Used by CloudGoat to initialise and deploy the vulnerable AWS infrastructure	Terraform initialisation completed successfully

2.2 AWS CLI & Tool Configuration

The following tools were used to set up, deploy, and assess the CloudGoat AWS environment. AWS CLI was used to interact with and enumerate AWS resources, while CloudGoat and Terraform were used to deploy the vulnerable training scenario. AWS CloudShell provided the command-line environment for running the required commands.

Tool / Service	Version	Installation Method	Purpose in This Task
AWS CLI	AWS CLI v2 (pre-installed in AWS CloudShell)	Available in AWS CloudShell; no separate installation required	Used to authenticate to AWS, verify the active AWS identity, enumerate EC2 instances, S3 buckets, IAM users, and IAM roles, and review deployed resources.

Tool / Service	Version	Installation Method	Purpose in This Task
AWS IAM	AWS Managed Service	Configured through AWS credentials and CLI profiles	Used to manage and review the IAM identities and permissions associated with the CloudGoat lab environment.
CloudGoat	v2.5.0	Installed using pip after cloning the CloudGoat repository	Used to deploy and manage the intentionally vulnerable iam_privesc_by_rollback AWS security training scenario.
Terraform	Terraform 1.5.0 or later	Installed/configured as a CloudGoat prerequisite	Used by CloudGoat to initialise and provision the AWS infrastructure required for the vulnerable scenario.
AWS CloudShell	AWS Managed Service	Accessed through the AWS Management Console; no local installation required	Provided the browser-based Linux shell used to run AWS CLI, CloudGoat, Python, and Terraform commands.
Python 3	Python 3.13	Available in the AWS CloudShell environment	Used to run CloudGoat and Python-based tools and scripts.
Git	Pre-installed in AWS CloudShell	Available in AWS CloudShell; no separate installation required	Used to clone the CloudGoat repository from GitHub.
AWS CLI Profile (cloudgoat-lab)	Custom AWS CLI profile	Configured using AWS CLI credentials/profile configuration	Used to identify and manage the AWS account used for the authorised CloudGoat lab environment.
Threat Dragon	Web-based tool	Accessed through the web interface	Used in Phase A to create a visual cloud threat model using the STRIDE methodology.

Key Configuration Commands Used

The following commands were used during the setup and configuration of the authorised CloudGoat AWS lab environment. Sensitive access key and secret key values have been omitted from the report.

1. Configure CloudGoat AWS Profile

```
cloudgoat config profile
```

The command completed without displaying an error, and the CloudGoat AWS profile configuration was saved.

2. Verify AWS CLI Configuration

```
aws configure list
```

3. Check Available AWS CLI Profiles

```
aws configure list-profiles
```

Output:

default

cybrisfun

cli-tips

4. Verify AWS Identity

The AWS identity was checked using:

```
aws sts get-caller-identity
```

The initial verification returned an `InvalidClientTokenId` error because the configured credentials were invalid:

An error occurred (`InvalidClientTokenId`) when calling the `GetCallerIdentity` operation:

The security token included in the request is invalid.

The credentials/profile configuration was subsequently reviewed and corrected before continuing with the CloudGoat lab.

5. Verify CloudGoat Installation

```
cloudgoat --help
```

CloudGoat successfully displayed the available commands and scenarios, confirming that the CloudGoat CLI was installed and accessible.

The available scenarios included:

```
iam_privesc_by_rollback
```

```
iam_privesc_by_key_rotation
```

```
iam_privesc_by_attachment
```

```
iam_enum_basics
```

```
iam_privesc_by_ec2
```

6. Verify Terraform Initialisation

Terraform was initialised successfully by CloudGoat. The terminal output confirmed:

Terraform has been successfully initialized!

and:

```
[cloudgoat] terraform init completed with no error code.
```

This confirmed that the Terraform environment was successfully prepared for deployment of the CloudGoat vulnerable scenario.

2.3 AI Tool Usage Declaration

AI Tool	Used For	What Was NOT Done with AI
ChatGPT	Used to explain cloud security concepts, clarify AWS and CloudGoat setup steps, help interpret AWS CLI outputs, assist with threat modelling, suggest MITRE ATT&CK mappings, organise findings, and support the preparation and formatting of the final report and documentation.	ChatGPT was not used to execute AWS or CloudGoat commands, access the AWS account, deploy cloud resources, produce actual CLI outputs, or create technical evidence and screenshots.
Claude	Used to help structure the Phase C attack-surface table and Phase D risk matrix based on the findings and outputs provided by me.	ChatGPT did not independently discover or verify cloud resources. The technical findings and evidence were based on the AWS CloudShell commands and outputs collected during the lab.

3.0 Methodology — Phase Execution

Phase A: Understand the principles of cloud threat modeling using STRIDE and MITRE ATT&CK frameworks.

Phase Objective	Understand the principles of cloud threat modeling using STRIDE and MITRE ATT&CK frameworks.
Estimated Time	60 minutes
Evidence File(s)	phaseA_threatmodel.png

Actions Taken

During Phase A, I studied the fundamentals of cloud threat modelling and reviewed the **STRIDE** methodology and **MITRE ATT&CK for Enterprise/Cloud** concepts. I focused on understanding how common threat categories can apply to AWS services such as EC2, S3, IAM users, and IAM roles.

I reviewed the six STRIDE threat categories:

- **Spoofing** – An attacker using stolen or compromised AWS credentials to impersonate a legitimate IAM identity.
- **Tampering** – Unauthorised modification of cloud resources, IAM policies, or stored data.
- **Repudiation** – An attacker performing actions without sufficient logging or monitoring, making the activity difficult to trace.

- **Information Disclosure** – Unauthorised exposure of sensitive data stored in S3 or accessible through cloud resources.
- **Denial of Service** – Actions that could disrupt or prevent legitimate access to cloud services or resources.
- **Elevation of Privilege** – Exploiting excessive IAM permissions or misconfigured roles to gain higher levels of access.

I then considered how these threats could apply to the CloudGoat AWS environment. For example, an IAM role with excessive permissions could create an **Elevation of Privilege** risk, while an improperly secured S3 bucket could result in **Information Disclosure**.

I also reviewed relevant MITRE ATT&CK cloud techniques, including **T1078 (Valid Accounts)**, **T1087 (Account Discovery)**, **T1580 (Cloud Infrastructure Discovery)**, **T1530 (Data from Cloud Storage Object)**, and **T1098 (Account Manipulation)**. These techniques helped me understand how an attacker could discover AWS resources, use valid credentials, access cloud storage, or manipulate identities and permissions.

Finally, I created a **Threat Dragon threat model diagram** representing the relationship between an EC2 instance, IAM permissions/role, and an S3 bucket. The diagram was used to identify potential STRIDE threats and demonstrate possible attack paths within the cloud environment.

Key Observations

This phase helped me understand that cloud threat modelling is not only about identifying vulnerabilities in individual services but also about analysing the relationships between **identities, permissions, compute resources, and data**. In the CloudGoat environment, IAM permissions are particularly important because overly broad permissions can allow an attacker to move from a lower-privileged identity to more privileged resources.

The STRIDE model provided a structured way to think about different categories of threats, while MITRE ATT&CK provided a way to relate potential attacker behaviour to recognised techniques. I also learned that a misconfiguration in one AWS service can affect the security of other connected resources. For example, an EC2 instance with an overly permissive IAM role could potentially access sensitive S3 data.

The main security risk category addressed in this phase was **excessive permissions and insecure cloud configurations**, which are important because attackers can potentially use legitimate cloud functionality and authorised credentials to access resources without needing to exploit a traditional software vulnerability.

Evidence Produced

- **phaseA_threatmodel.png** — Threat Dragon diagram showing the AWS cloud environment, EC2-to-S3 relationship, IAM access, and potential STRIDE-based threats.

Phase B: Deploy the CloudGoat vulnerable environment in your AWS Free Tier account.

Phase Objective	Deploy the CloudGoat vulnerable environment in your AWS Free Tier account.
Estimated Time	90 minutes

Evidence File(s)	phaseB_resources.png
------------------	----------------------

Actions Taken

During Phase B, I set up the authorised AWS CloudGoat vulnerable environment for the cloud security assessment. The purpose of this phase was to create a controlled AWS environment where I could safely study cloud misconfigurations, IAM permissions, and potential privilege-escalation risks.

I first prepared the AWS CloudShell environment and verified that the CloudGoat repository and required project files were available. I installed CloudGoat and configured the required dependencies, including Terraform, which CloudGoat uses to provision the vulnerable AWS infrastructure.

I then configured the AWS environment and CloudGoat profile. During the initial setup, the AWS CLI returned an InvalidClientTokenId error because the configured credentials were invalid. I reviewed the available AWS CLI profiles and credential configuration and corrected the AWS authentication setup before continuing.

The AWS CLI configuration was reviewed using:

```
aws configure list
```

The configuration showed that credentials were being loaded from the shared credentials file and that the AWS region was configured as:

```
region : us-east-2
```

I also checked the available AWS CLI profiles using:

```
aws configure list-profiles
```

The available profiles included:

```
default
```

```
cybrisfun
```

```
cli-tips
```

CloudGoat was then configured for the authorised AWS environment using:

```
cloudgoat config profile
```

I selected the appropriate AWS credentials/profile for the CloudGoat lab and configured the IP whitelist required by CloudGoat. The whitelist was used to restrict the vulnerable environment to the authorised IP address.

I then deployed the CloudGoat scenario:

```
cloudgoat create iam_privesc_by_rollback
```

During deployment, CloudGoat used Terraform to initialise and provision the required AWS resources.

Terraform successfully completed the initialisation process, with the following confirmation:

```
Terraform has been successfully initialized!
```

```
[cloudgoat] terraform init completed with no error code.
```

The iam_privesc_by_rollback scenario was selected because it provides an intentionally vulnerable AWS environment for studying IAM permissions and potential privilege escalation. After deployment, I reviewed the AWS environment to identify the resources created by CloudGoat, including IAM roles, IAM users, EC2 instances, and S3 resources.

The deployed resources were then used as the foundation for the Phase C attack-surface enumeration and Phase D threat modelling activities.

Key Observations

This phase helped me understand how a cloud security training environment can be deployed using Infrastructure as Code and how vulnerable cloud resources can be created in a controlled AWS account. I learned that CloudGoat acts as the framework for managing the vulnerable scenario, while Terraform performs the underlying infrastructure provisioning.

A key observation was the importance of **AWS identity and access management** during cloud environment deployment. CloudGoat requires valid AWS credentials with sufficient permissions to create and manage the resources needed for the scenario. The initial `InvalidClientTokenId` error demonstrated that even when the CloudGoat tool is correctly installed, incorrect or expired AWS credentials can prevent successful communication with AWS.

The deployment also showed the relationship between different AWS resources. The CloudGoat scenario was not limited to a single service; it involved identities such as IAM users and roles alongside other AWS resources. These relationships are important when assessing cloud security because an identity with excessive permissions may be able to access or modify other resources.

The main security concept addressed in this phase was **secure identity and permission management**. The CloudGoat environment intentionally contains vulnerable configurations that can be analysed in later phases. Understanding how these resources are deployed and connected provides the foundation for identifying attack surfaces and potential privilege-escalation paths.

Evidence Produced

- **phaseB_resources.png** — Screenshot of the AWS Console showing the resources deployed by the CloudGoat `iam_privesc_by_rollback` scenario.
- **CloudGoat deployment output** — Terminal output confirming that the CloudGoat scenario was initialised and deployed using Terraform.
- **Terraform initialisation output** — Output confirming Terraform has been successfully initialized and that Terraform completed with no error code.
- **AWS CLI configuration output** — Output from `aws configure list` showing the configured AWS region and credential source.
- **AWS CLI profile enumeration output** — Output from `aws configure list-profiles` showing the available AWS CLI profiles.
- **CloudGoat configuration** — The CloudGoat AWS profile and IP whitelist were configured for the authorised lab environment.

Phase C: Enumerate all exposed services and identify potential attack vectors.

Phase Objective	Enumerate all exposed services and identify potential attack vectors.
Estimated Time	120 minutes
Evidence File(s)	phaseC_attack_surface.xlsx

Actions Taken

During Phase C, I analysed the AWS resources deployed as part of the CloudGoat iam_privesc_by_rollback scenario to identify exposed services and potential attack vectors. The main focus was on understanding what resources were present, how they were configured, and whether any permissions or exposure could create security risks.

I used AWS CLI commands to enumerate the resources in the authorised AWS environment. The assessment focused on EC2 instances, S3 buckets, IAM users, and IAM roles.

For EC2 resource enumeration, I used:

```
aws ec2 describe-instances
```

This command was used to identify active and deployed EC2 instances and review information such as instance IDs, state, private or public IP addresses, and other configuration details.

I also enumerated S3 resources using:

```
aws s3 ls
```

This allowed me to identify the S3 buckets available in the AWS environment and consider whether they could represent potential data-access or information-disclosure risks.

IAM resources were also reviewed to understand the identities and permissions available within the environment. This was important because the CloudGoat scenario focuses on IAM privilege escalation. I examined the available IAM users and roles and considered how excessive or misconfigured permissions could potentially be abused.

The findings from the resource enumeration were organised into an attack-surface table. For each identified resource, I documented the AWS service, the potential security concern, the possible attack vector, relevant MITRE ATT&CK technique mapping, and recommended security controls.

The assessment considered potential attack surfaces such as:

- **EC2 instances** — Publicly accessible or externally exposed instances could increase the attack surface if unnecessary network access is permitted.
- **S3 buckets** — Misconfigured bucket permissions or public exposure could potentially allow unauthorised access to stored data.
- **IAM users** — Compromised or misused valid credentials could allow an attacker to access AWS resources.
- **IAM roles** — Excessive permissions or insecure trust relationships could potentially enable privilege escalation or unauthorised access.
- **Cloud infrastructure** — Enumerating AWS resources can provide an attacker with information about the environment and help identify further attack paths.

I then mapped relevant findings to MITRE ATT&CK techniques, including **T1078 (Valid Accounts)**, **T1087 (Account Discovery)**, **T1580 (Cloud Infrastructure Discovery)**, **T1530 (Data from Cloud Storage Object)**, and **T1098 (Account Manipulation)**.

The results were documented in the required Excel attack-surface table.

Key Observations

This phase helped me understand that identifying a cloud attack surface requires looking beyond individual services and considering how resources are connected through IAM identities and permissions. An EC2 instance,

S3 bucket, or IAM role may appear secure individually, but excessive permissions or an insecure relationship between resources can create a potential attack path.

One of the main observations was the importance of IAM permissions in the CloudGoat environment. Since the scenario focuses on IAM privilege escalation, understanding which users and roles exist and what permissions they have is critical when assessing the potential for an attacker to increase their access.

I also learned that cloud resource enumeration is an important stage of an attack. An attacker who obtains valid AWS credentials may first discover available accounts, roles, EC2 instances, and S3 buckets before attempting further actions. This is why techniques such as Account Discovery and Cloud Infrastructure Discovery are relevant to the assessment.

The S3 resources also demonstrated the importance of protecting cloud storage. If an S3 bucket is incorrectly configured to allow public or unauthorised access, sensitive information could potentially be exposed. Similarly, EC2 resources with unnecessary public exposure can increase the overall attack surface.

The main security risk categories addressed in this phase were **excessive IAM permissions, insecure identity configurations, cloud resource exposure, and potential data exposure**. These risks matter because attackers can use legitimate AWS functionality and valid credentials to discover and access resources without necessarily exploiting a traditional software vulnerability.

Evidence Produced

- **phaseC_attack_surface.xlsx** — Attack surface table documenting the AWS resources identified during enumeration, potential attack vectors, MITRE ATT&CK mappings, and recommended security controls.

Phase D: Build a complete threat model including risk ratings and mitigations.

Phase Objective	Build a complete threat model including risk ratings and mitigations.
Estimated Time	150 minutes
Evidence File(s)	phaseD_riskmatrix.png

Actions Taken

During Phase D, I extended the security assessment by analysing the attack surfaces identified in Phase C and developing a structured threat model and risk matrix. The purpose of this phase was to determine which identified threats presented the greatest risk and to recommend appropriate security controls to reduce or manage those risks.

I reviewed the Phase C findings relating to **EC2 instances, S3 buckets, IAM users, and IAM roles** and considered the potential threats associated with each resource. I assessed the threats based on two main factors:

- **Likelihood** — How likely the identified threat could be exploited based on the observed configuration and potential attack path.
- **Impact** — The potential effect on confidentiality, integrity, or availability if the threat were successfully exploited.

I then assigned risk ratings based on the combination of likelihood and impact. The identified risks included potential **IAM privilege escalation, unauthorised access using valid credentials, cloud infrastructure discovery, S3 data exposure, and excessive permissions.**

The threat model also considered the relationship between AWS identities and resources. For example, an IAM identity with excessive permissions could potentially access or modify other AWS resources. Similarly, an EC2 instance associated with an overly permissive IAM role could create a potential path to access additional cloud services.

I mapped the identified threats to relevant MITRE ATT&CK techniques, including:

- **T1078 – Valid Accounts**
- **T1087 – Account Discovery**
- **T1580 – Cloud Infrastructure Discovery**
- **T1530 – Data from Cloud Storage Object**
- **T1098 – Account Manipulation**

For each identified threat, I documented recommended mitigations. These included applying **IAM least privilege**, regularly reviewing IAM permissions, restricting unnecessary public exposure, securing S3 bucket access, monitoring cloud activity, and protecting sensitive data through appropriate security controls such as encryption.

The results were organised into the Phase D risk matrix, which records the identified threat, affected resource, likelihood, impact, risk score/rating, MITRE ATT&CK mapping, and recommended mitigation.

The risk matrix was then prepared as the required evidence for the phase.

Key Observations

This phase helped me understand that identifying an attack surface is only the first step in a cloud security assessment. A security engineer must also determine which findings represent the greatest risk and prioritise them based on their likelihood and potential impact.

One of the key observations was that IAM permissions can have a significant impact on the overall security of a cloud environment. A single identity with excessive permissions may potentially provide access to multiple AWS services and resources. Therefore, applying the principle of least privilege and regularly reviewing permissions are important security controls.

I also observed that cloud security risks are often interconnected. For example, an attacker who obtains valid credentials could perform account or infrastructure discovery, identify useful resources, and potentially attempt to access sensitive S3 data or manipulate permissions. This demonstrates why threat modelling needs to consider potential attack paths rather than evaluating each AWS resource in isolation.

The risk assessment also highlighted the importance of protecting **cloud storage and identity systems**. S3 buckets containing sensitive information require appropriate access controls, while IAM users and roles should have only the permissions necessary to perform their intended functions.

The main security risk categories addressed in this phase were **privilege escalation, excessive IAM permissions, unauthorised access, cloud resource discovery, and potential data exposure**. Assigning likelihood and impact ratings helped prioritise these risks and identify practical mitigations that could reduce the overall security exposure.

Evidence Produced

- **phaseD_risk_matrix.xlsx** — Risk matrix documenting identified threats, affected AWS resources, likelihood, impact, risk ratings, MITRE ATT&CK mappings, and recommended mitigations.

4.0 Findings

4.1 Findings Summary

#	Finding Title	Type / Category	Cloud Service / Resource	MITRE Ref.	Phase	Severity	Evidence Ref.
1	Potential IAM Privilege Escalation	Privilege Escalation Path / Access Control Weakness	IAM Role / IAM Permissions	T1098	Phase C / D	Critical	Phase C attack surface table / Phase D risk matrix
2	Potential Unauthorised Access Using Valid Credentials	Access Control Weakness / Credential Risk	IAM User / AWS Credentials	T1078	Phase C / D	Critical	Phase C attack surface table / Phase D risk matrix
3	Potential S3 Data Exposure	Misconfiguration / Access Control Weakness / Data Exposure	Amazon S3 Bucket	T1530	Phase C / D	Critical	Phase C attack surface table / Phase D risk matrix

#	Finding Title	Type / Category	Cloud Service / Resource	MITRE Ref.	Phase	Severity	Evidence Ref.
4	Cloud Infrastructure Discovery Exposure	Information Disclosure / Reconnaissance	EC2 Instances / AWS Cloud Infrastructure	T1580	Phase C / D	High	Phase C attack surface table / Phase D risk matrix
5	AWS Account and Role Discovery	Information Disclosure / Reconnaissance	IAM Users and IAM Roles	T1087	Phase C / D	High	Phase C attack surface table / Phase D risk matrix

4.2 Detailed Finding Analysis

[Write a detailed analysis card for each finding in the summary table. Aim for 3–5 detailed cards; additional minor findings may appear in the summary table only.]

Finding 1: Potential IAM Privilege Escalation

Field	Details
Finding Title	Potential IAM Privilege Escalation
Type / Category	Privilege Escalation Path / Access Control Weakness / IAM Policy Gap
Cloud Service / Resource	AWS IAM Roles and IAM Permissions within the CloudGoat iam_privesc_by_rollback scenario
Description	The CloudGoat scenario was specifically designed to demonstrate risks associated with vulnerable IAM permissions and potential privilege escalation. During the assessment, IAM roles and

Field	Details
	permissions were reviewed to understand whether an identity with lower privileges could potentially gain access to more powerful permissions. Excessive permissions or the ability to modify or roll back IAM policies can create a potential path to higher levels of access.
How Identified	The finding was identified during the Phase C review of IAM users, roles, and permissions within the CloudGoat environment. The iam_privesc_by_rollback scenario was also analysed as part of the CloudGoat deployment and threat-modelling process.
MITRE ATT&CK Reference	T1098 – Account Manipulation. This technique is relevant to potential manipulation of account permissions or access to increase privileges.
Business / Security Impact	Successful exploitation of an IAM privilege-escalation path could allow an attacker to gain access to additional AWS services or resources. Depending on the permissions obtained, this could affect the confidentiality, integrity, and availability of cloud resources and potentially lead to further compromise of the AWS environment.
Severity / Impact	Critical
Evidence Reference	phaseC_attack_surface.xlsx and phaseD_risk_matrix.xlsx; Phase D risk matrix entry for potential IAM privilege escalation.

Finding 2: Potential Unauthorised Access Using Valid Credentials

Field	Details
Finding Title	Potential Unauthorised Access Using Valid Credentials
Type / Category	Access Control Weakness / Credential Risk
Cloud Service / Resource	AWS IAM User and AWS Credentials
Description	The CloudGoat environment required valid AWS credentials to deploy and manage the vulnerable scenario. The assessment demonstrated the importance of protecting these credentials because an attacker who obtains valid AWS credentials may be able to interact with cloud resources using

Field	Details
	legitimate AWS functionality. The initial AWS CLI authentication error also highlighted the importance of correctly managing and validating credentials before accessing the environment.
How Identified	The finding was identified during AWS CLI configuration and identity verification using <code>aws configure list</code> , <code>aws configure list-profiles</code> , and <code>aws sts get-caller-identity</code> . The potential risk was then considered during the Phase C attack-surface assessment.
MITRE ATT&CK Reference	T1078 – Valid Accounts. This technique is relevant because an attacker who obtains legitimate AWS credentials could potentially use them to access cloud resources.
Business / Security Impact	Compromised AWS credentials could allow an attacker to access resources available to the associated IAM identity. Depending on the permissions assigned, this could lead to data exposure, resource modification, privilege escalation, or further compromise of the cloud environment.
Severity / Impact	Critical
Evidence Reference	AWS CLI configuration and verification outputs; <code>phaseC_attack_surface.xlsx</code> ; <code>phaseD_risk_matrix.xlsx</code> .

Finding 3: Potential S3 Data Exposure

Field	Details
Finding Title	Potential S3 Data Exposure
Type / Category	Misconfiguration / Access Control Weakness / Data Exposure
Cloud Service / Resource	Amazon S3 Buckets identified during the CloudGoat environment assessment
Description	S3 buckets were identified during the Phase C attack-surface enumeration. Cloud storage can represent a significant security risk if bucket policies, ACLs, or IAM permissions allow unintended access to stored objects. The assessment therefore considered S3 resources as potential attack surfaces where misconfigured access controls could lead to unauthorised data access.
How Identified	S3 resources were enumerated using the AWS CLI command <code>aws s3 ls</code> . The identified buckets were then considered during the attack-surface analysis and risk assessment.
MITRE ATT&CK Reference	T1530 – Data from Cloud Storage Object. This technique is relevant to the potential unauthorised access or collection of information stored in cloud storage.
Business / Security Impact	If sensitive information stored in an S3 bucket were accessible to an unauthorised party, it could result in data disclosure and potential privacy, regulatory, or business consequences. The impact would depend on the sensitivity of the data stored in the bucket.
Severity / Impact	Critical

Field	Details
Evidence Reference	AWS CLI S3 enumeration output; phaseC_attack_surface.xlsx; phaseD_risk_matrix.xlsx.

5.0 Risk Assessment & Cloud Threat Model

[This section is required for all tasks. Complete both sub-sections using the outputs from your Phase D threat modelling work and your findings from Section 4.]

5.1 Cloud Security Control Gaps & Defensive Coverage

<i>Finding / Gap</i>	<i>Observable / Trigger in Cloud Telemetry</i>	<i>Recommended Control</i>	<i>AWS Service / Tool for Implementation</i>
Potential IAM Privilege Escalation	IAM policy changes, role modifications, or unusual API calls involving IAM permissions recorded in CloudTrail.	Apply least-privilege IAM policies, restrict IAM policy modification permissions, and alert on unexpected privilege changes.	AWS CloudTrail, Amazon CloudWatch Alarms, IAM Access Analyzer, AWS Config
Potential Unauthorised Access Using Valid Credentials	AWS API activity from unexpected locations, unusual login activity, or API calls that differ from normal user behaviour.	Enforce MFA, rotate credentials, remove unused access keys, and apply least-privilege permissions.	AWS CloudTrail, Amazon GuardDuty, IAM, AWS IAM Access Analyzer
Potential S3 Data Exposure	Unexpected GetObject or ListBucket API calls, especially from unauthorised identities or unexpected sources.	Enable S3 Block Public Access, review bucket policies and ACLs, restrict access through IAM, and encrypt sensitive data.	Amazon S3 Block Public Access, AWS Config, IAM Access Analyzer for S3, AWS CloudTrail
Cloud Infrastructure Discovery Exposure	Repeated DescribeInstances, DescribeSecurityGroups, or similar discovery API calls by an identity that does not normally perform reconnaissance.	Restrict EC2 read permissions to required users and roles and monitor unusual enumeration activity.	AWS CloudTrail, Amazon GuardDuty, AWS IAM, Amazon CloudWatch
AWS Account and Role Discovery	Repeated IAM discovery API calls such as ListUsers, ListRoles, or GetRole in CloudTrail activity.	Apply least privilege to IAM discovery permissions and monitor unusual IAM enumeration activity.	AWS CloudTrail, Amazon GuardDuty, IAM Access Analyzer, Amazon CloudWatch Alarms

5.2 Risk Exposure Over Time

Risk 1 — Potential IAM Privilege Escalation:

If the identified IAM privilege-escalation path remains unaddressed, an attacker who gains access to a lower-privileged identity could potentially use excessive permissions or IAM policy weaknesses to obtain higher levels of access. Over time, this could increase the attacker's ability to access additional AWS resources, modify permissions, and potentially move further through the cloud environment.

Risk 2 — Potential Unauthorised Access Using Valid Credentials:

If AWS credentials are compromised and remain active, an attacker could continue using legitimate AWS API calls under the associated identity. Based on the Phase C findings, this could provide opportunities to enumerate IAM and EC2 resources, access S3 resources where permissions allow, and identify additional attack paths within the CloudGoat environment.

Risk 3 — Potential S3 Data Exposure:

If S3 access controls remain incorrectly configured, unauthorised users with sufficient access could potentially retrieve information stored in cloud storage. Over time, continued exposure could increase the likelihood of sensitive data disclosure and make it more difficult to determine whether data has been accessed without adequate monitoring and logging.

6.0 Recommendations

#	Finding	Specific Remediation Action (with Policy / CLI where applicable)	Priority	Standard / Reference
1	Potential IAM Privilege Escalation	Review the IAM policies associated with the affected role and remove permissions that are not required. Restrict permissions that allow users or roles to modify IAM policies or assume higher-privileged roles. Apply least privilege and regularly review role permissions. Use IAM Access Analyzer to identify unintended access paths and monitor IAM changes through CloudTrail.	Immediate	CIS AWS Foundations Benchmark; NIST SP 800-53 AC-6 (Least Privilege); ISO/IEC 27001 Annex A
2	Potential Unauthorised Access Using Valid Credentials	Review all IAM access keys associated with the lab identities and remove unused keys. Rotate credentials where appropriate and enable MFA for privileged identities. Review CloudTrail activity for unusual API calls or unexpected access patterns. Avoid using long-term credentials where temporary credentials are available.	Immediate	CIS AWS Foundations Benchmark; NIST SP 800-53 IA-2 / IA-5; ISO/IEC 27001 Annex A
3	Potential S3 Data Exposure	Review S3 bucket policies, ACLs, and IAM permissions. Enable S3 Block Public Access and ensure that only authorised identities can access objects. For a bucket requiring private access, verify	Immediate	CIS AWS Foundations Benchmark; NIST SP 800-53 AC-3 / SC-

#	Finding	Specific Remediation Action (with Policy / CLI where applicable)	Priority	Standard / Reference
		that public access is blocked and review permissions using IAM Access Analyzer. Enable encryption for sensitive data stored in S3.		28; ISO/IEC 27001 Annex A
4	Cloud Infrastructure Discovery Exposure	Restrict unnecessary Describe* permissions for EC2 and other cloud resources using least-privilege IAM policies. Review which identities can enumerate infrastructure and monitor unusual discovery activity through CloudTrail and GuardDuty.	Short-term	NIST SP 800-53 AC-6; CIS AWS Foundations Benchmark
5	AWS Account and Role Discovery	Review IAM permissions that allow users to enumerate accounts, users, and roles. Remove unnecessary IAM discovery permissions where they are not required for legitimate administrative tasks. Monitor unusual IAM enumeration activity using CloudTrail and CloudWatch alerts.	Short-term	NIST SP 800-53 AC-6; CIS AWS Foundations Benchmark

6.2 Strategic & Operational Improvements

Beyond addressing the individual findings, the following improvements would help prevent similar IAM, credential, S3, and cloud-environment risks from recurring:

- **Implement continuous AWS security monitoring:** Enable **AWS Security Hub** and **AWS Config** to continuously assess the AWS account against security best practices and identify configuration deviations. This would help detect issues related to IAM permissions, publicly accessible resources, and other configuration weaknesses identified during the assessment.
- **Strengthen IAM governance and least-privilege management:** Establish regular reviews of IAM users, roles, access keys, and permissions. Use **IAM Access Analyzer** to identify unintended access paths and remove excessive permissions that could contribute to privilege-escalation risks.
- **Improve detection of suspicious cloud activity:** Configure **AWS CloudTrail** across the environment and create **CloudWatch alarms** for high-risk actions such as IAM policy changes, role modifications, unusual credential use, and suspicious S3 access. This would improve visibility into the types of activity considered during the Phase C attack-surface assessment.

7.0 Reflection

Q1 How does improper IAM configuration expand an organization's attack surface?

Improper IAM configuration expands the attack surface by giving users or roles more permissions than they actually need. In my CloudGoat lab, the `iam_privesc_by_rollback` scenario demonstrated how weaknesses in IAM permissions could potentially create a path from a lower-privileged identity to higher privileges. I also identified IAM roles and permissions as an important attack surface during Phase C because excessive permissions could allow an attacker with valid credentials to discover resources, access additional AWS services, or potentially escalate privileges. This shows why applying least privilege, regularly reviewing IAM policies, and monitoring IAM changes are important for reducing cloud attack paths.

Q2 Which STRIDE category was most prevalent in your CloudGoat environment? Why?

The most prevalent STRIDE category in my CloudGoat environment was **Elevation of Privilege**. This was mainly because the lab scenario, `iam_privesc_by_rollback`, focused on identifying how weaknesses in IAM permissions could potentially allow a lower-privileged identity to gain higher privileges. During the assessment, I also identified IAM roles, permissions, and credential-based access as significant attack surfaces. This showed me that improper IAM configuration can create privilege-escalation paths that may allow an attacker to access additional AWS resources and increase the overall impact of a compromise.

Q3 How would you communicate high-risk findings from your threat model to non-technical executives?

I would explain the findings in terms of **business risk rather than technical details**. For example, I would explain that the IAM privilege-escalation risk could allow an unauthorised person who gains initial access to obtain greater control over cloud resources, while the potential S3 exposure could lead to sensitive business information being accessed without permission. I would clearly communicate the **potential business impact, likelihood, severity, and recommended action**, using a simple risk rating such as Critical or High. I would then focus on what management needs to know: **what could happen, how it could affect the organisation, what needs to be fixed, and how quickly it should be addressed**, rather than explaining detailed IAM policies or AWS commands.

Q4 If you discovered similar misconfigurations in production, what remediation steps would you prioritize first?

If I discovered similar misconfigurations in a production AWS environment, I would first **contain the highest-risk issues** by reviewing and restricting excessive IAM permissions and disabling or rotating any potentially compromised credentials. I would then secure S3 resources by checking bucket policies, blocking unnecessary public access, and protecting sensitive data. After that, I would review IAM roles and permissions using least privilege, enable or verify CloudTrail and security monitoring, and investigate recent activity for signs of unauthorised access. Finally, I would document the findings, assign remediation priorities based on business impact, and establish regular reviews to prevent the same issues from recurring.

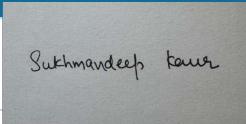
8.0 Deliverables Submission Checklist

✓	Phase	Deliverable Description	Your Filename	Status
✓	Phase A	Theory evidence — Threat Dragon STRIDE threat model and MITRE ATT&CK mapping	phaseA_threatmodel.png	Complete
✓	Phase B	Environment setup evidence — CloudGoat deployment and AWS resource evidence	phaseB_resources.png	Complete
✓	Phase C	Core execution evidence — AWS service enumeration and attack surface analysis	phaseC_attack_surface.xlsx	Complete
✓	Phase D	Extension & risk model evidence — Risk matrix and threat assessment	phaseD_riskmatrix.xlsx	Complete
✓	Phase E	N/A	N/A	N/A
✓	Phase F	Documentation & Reporting — Final professional report	AWS_ThreatModel_Report.pdf	Complete

Declaration & Sign-Off

I confirm that:

- All work in this report is my own except where AI usage is explicitly declared in Section 2.3.
- All technical activities were performed exclusively within the authorised cloud environments listed in Section 1.3.
- No external AWS accounts, production environments, third-party cloud resources, or real customer data were accessed during this task.
- All AWS credentials, access keys, session tokens, and account identifiers used during this task have been redacted in evidence files before submission.
- I have reviewed this report for accuracy, completeness, and professional presentation before submission.

Intern Full Name	Signature	Date of Submission
Sukhmandeep Kaur		29-07-2026

EncryptEdge Labs Limited — Junior Cloud Security Engineer Internship Programme

Company No. 15830711 | United Kingdom | encryptedgelabs.com

Copyright © 2026 EncryptEdge Labs. All rights reserved. | Report Template v3.0